29/6/24

Case study

1. BrightMark is a medium sized online shopping company. Customers use it's website and mobile application to purchase products.

The company stores:

1) Customer names
2) Email addresses
3) Phone-nos
4) Delivery addresses
5) Passwords
6) Order information
7) Payment-related information

BrightMart has around 100 employees. The company recently hired several new employees. To make things easier, the IT department gave employees access to different internal systems.

2. Hoseever, the company has the following security weaknesses:

- Some employees use simple passwords such as BrightMart123.
- Many employees use the same passwords for multiple systems.
- Software updates are sometimes delayed
- The company does not regularly conduct employee cybersecurity training.
- There is no multi-factor authentication for some important accounts.
- Employees can access sensitive information that they do not necessarity need for their jobs.
- Backups are performed only once a month.

The Incident

One Monday morning, an employee, name Rahul receives an email.
Subject: Urgent — Your Account Will be Suspended

The email appears to come from the company's IT department.

It says:
"Your company account will be suspended today click the link below and verify your password immediately."

Teacher's Signature:

Rahul clicks the link.

The page looks almost identical to the company's login page.

He enters his username and password.

Rahul does not realize that the website is controlled by an attacker

The attacker now has Rahul's login credentials.

Stage 1 — Unauthorized Access

The attacker uses Rahul's credentials to access BrightMart's internal system.
Because Rahul uses the same password for another system, the attacker is also able to access that system.
The attacker discovers that Rahul has access to customer information.
The attacker downloads a large amount of customer data.

- What Cybersecurity problem has occured?

Stage 2 – Malware Attack

- The attacker sends another email to Rahul containing a melicious attachment.
Rahul open the attachment.
Malware is installed on this computer.
The malware begins communicating with the attacker's system.
The attacker now attempts to move from Rahul's computer to other systems within BrightMart's network.

- Which vulnerability allowed the attacker to move further into the organization?

Stage 3 – Ransomware

- Two days later, employees arrive at work and discover that they cannot access important files.
- A message appears on their computer "Your files have been encrypted. Pay the ransom to recover them".
- The company's customer database and several important business files are encrypted.
- Unfortunatley, the company's most recent backup is almost a month old.

Teacher's Signature: .....

- Bright Mart's website stops working.
- Customers cannot place orders.
- The customer-support team cannot access customer records.

Stage 4 - Business impact

- BrighMart's now faces several problems.
- Financial Impact
- The company loses sales because it's website is unavailable.
- Data impack
- Customer information may have been stolen.
- Operational impact
- Employees cannot access important systems.
- Reputation Impact
- Customers lose confidence in the company.
- Legal / Compliance Impact
- The company may face regulatory or legal consequences depending on what information was exposed and which laws apply

Group 1 - Identify the Threats

What threats are present in this Case?

Group 2 - Identify the Vulnerabilities

What weaknesses in BrightMart's security allowed the attack to succeed?

Page No.:
Date: / /

Group 3 - Apply the CIA Triad

- Was confidential information exposed?
- Was information changed or damaged?
- Were systems available to legitimate users?

Group 4 - Security Solutions

- Who is responsible for cybersecurity?
- Was phishing the only problem?
- What was the biggest vulnerability?

Answers

- What cybersecurity problem has occured?

→
1) Phishing
2) Unauthorized access
3) Credential theft
4) Data breach

- Which vulnerability allowed the attacker to move further into the organization?

→
1) Weak passwords
2) Excessive user privileges
3) Lack of MFA (Multi-factor Authentification)
4) Poor network security
5) Lack of employee awareness
6) Outdated software

- What threats are present in this case?

→ 1) Phishing
2) Malware
3) Ransomware
4) Credential theft
5) Unauthorized access
6) Data theft

- What weaknesses in BrightMart's security allowed the attack to succeed?

→

Vulnerability - How it helped the attacker

1) weak password - Easier to compromise account
2) Password reuse - One stolen password gives access to multiple systems
3) No MFA - Stolen password may be enough to log in
4) Lack of training - Employee falls for phishing
5) Delayed updates - Vulnerable software may be exploited.
6) Excessive privileges - Attacker can access more data
7) Infrequent backups - Difficult to recover after ransomware

Teacher's Signature:

• Was confidential information exposed!
→ Yes, customers information was accessed /downloaded by the attacker.

• Was information changed or damaged!?
→ Potentially yes, The attacker could modify or encrypt files.

• Were systems available to legitimate users?
→ No, The website and internal systems became unavailable because of ransomwa

• Who is responsible for cybersecurity?
→ Not only the IT department! Every employe who uses the organization's systems has a role in cybersecurity.

• Was phishing the only problem!
→ No, phishing was the initial, but weaknesses such as password reuse, lack of MFA, excessive privileges, poor backups, and insufficient training allowed the attack to become much more damaging.

← tol

Teacher's Signature:

• What was the biggest vulnerability?

→ Poor backup practices were the biggest problem because Brightmart could not quickly recover from the ransomware.

✓ 2/18/26

Quick Assessment

1) What was the initial attack against Brightmart?

→ Phishing

2) Give three vulnerabilities that helped the attacker.

→ 1) weak or new password
2) Lack of MFA
3) Lack of employee cyber security training.

3) Which three security principles of the CIA Traid were affected?

→ 1) Confidentiality
2) Integrity
3) Availability.

Teacher's Signature:

4) What was the impact of ransomware on BrightMart?

→ The ransomware caused BrightMart's website and internal systems to stop working. It also encrypted or damaged important files, making it difficult for the company to recover its data.

5) Suggest three security controll BrightMart should implement.

→ 1) Implement Multi-Factor Authentication (MFA)

2) Provide regular cybersecurity awareness training.

3) Maintain regular backups.